

Manual: Segurança da Informação

ISO 27001/27002, Criptografia Simétrica/Assimétrica, Hash, Assinatura Digital, ICP-Brasil, Redes, Malwares, OWASP Top 10 e LGPD

CHANCELA EDITORIAL YLUNA85 LABS

Preparação Conjunta: Auditor Fiscal (TI) & Agente de Tributos Estaduais

Revisão Ortográfica e Glossário Geral de Siglas

Material de livre circulação interna. Revisado em Português Brasileiro (pt-BR).

1. Princípios de Segurança e Gestão com ISO/IEC 27001 e 27002

A Segurança da Informação visa proteger os ativos de informação contra uma ampla gama de ameaças, garantindo a continuidade do negócio, a conformidade legal e a mitigação de riscos operacionais. O pilar clássico de segurança é a Tríade CID (Confidencialidade, Integridade e Disponibilidade), complementada pelos princípios de Autenticidade, Irretratabilidade / Não Repúdio e Conformidade. A governança corporativa de segurança é padronizada internacionalmente pela família ABNT NBR ISO/IEC 27000.

- **A Tríade CID e Princípios Básicos**

Confidencialidade: Garantia de que a informação é acessível exclusivamente por pessoas, entidades ou processos autorizados; Integridade: Salvaguarda da exatidão e completude da informação e dos métodos de processamento, impedindo alterações não autorizadas; Disponibilidade: Garantia de que os usuários autorizados tenham acesso à informação e aos ativos correspondentes sempre que necessário; Autenticidade: Garantia da veracidade da identidade do emissor; Não Repúdio / Irretratabilidade: Impossibilidade de o autor negar a autoria de uma transação ou mensagem.

- **ABNT NBR ISO/IEC 27001:2022 (Requisitos do SGSI)**

Especifica os requisitos formais para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI). Adota a abordagem baseada em riscos e exige a elaboração da Declaração de Aplicabilidade (Statement of Applicability - SoA).

- **ABNT NBR ISO/IEC 27002:2022 (Código de Práticas e Controles)**

Guia de orientação que reúne 93 controles de segurança agrupados em 4 categorias/temas principais: 1. Controles Organizacionais (37 controles); 2. Controles de Pessoas (8 controles); 3. Controles Físicos (14 controles); 4. Controles Tecnológicos (34 controles).

- **Gestão de Incidentes de Segurança**

Ciclo formal de resposta a incidentes: Preparação, Identificação/Detecção, Contenção, Erradicação, Recuperação e Lições Aprendidas (Post-Mortem).

ALERTA DE PROVA - ISO 27001 VERSUS ISO 27002

A ISO/IEC 27001 estabelece os REQUISITOS mandatórios e é a única norma da família que permite certificação formal de uma organização. A ISO/IEC 27002 é um código de boas práticas com DIRETRIZES para a implementação dos controles do Anexo A da ISO 27001.

2. Criptografia Simétrica e Modos de Operação de Cifra de Bloco

A Criptografia Simétrica (ou de Chave Secreta) emprega uma única chave criptográfica compartilhada tanto para o processo de cifração quanto para o processo de decifração da mensagem. Destaca-se pelo altíssimo desempenho computacional e velocidade de processamento, sendo ideal para cifração massiva de bancos de dados fiscais e canais de comunicação em trânsito.

- Algoritmos Simétricos Fundamentais

DES (Data Encryption Standard - chave obsoleta de 56 bits vulnerável a força bruta); 3DES (Triple DES - aplica DES três vezes com chaves independentes, seguro porém lento); AES (Advanced Encryption Standard / Rijndael - padrão internacional do NIST com blocos fixos de 128 bits e tamanhos de chave de 128, 192 e 256 bits, imune a ataques práticos); RC4 (cifra de fluxo obsoleta); ChaCha20 (cifra de fluxo moderna de alta performance).

- Modos de Operação de Cifra de Bloco

Modos que definem como blocos sequenciais de texto claro são cifrados: 1. ECB (Electronic Codebook - cada bloco é cifrado independentemente com a mesma chave; INSEGURO pois preserva padrões repetitivos do texto original); 2. CBC (Cipher Block Chaining - cada bloco de texto claro sofre operação XOR com o bloco cifrado anterior antes de ser cifrado, exigindo um Vetor de Inicialização / IV aleatório); 3. CFB (Cipher Feedback) e OFB (Output Feedback) - transformam cifras de bloco em cifras de fluxo; 4. CTR (Counter Mode - cifra um contador sequencial com paralelismo total e alta velocidade); 5. GCM (Galois/Counter Mode - provê confidencialidade E autenticidade integrada / AEAD).

- O Desafio da Distribuição de Chaves

O principal ponto fraco da criptografia simétrica reside na necessidade de compartilhamento seguro da chave secreta entre as partes antes do início da comunicação.

A FALHA CRÍTICA DO MODO ECB

O modo ECB (Electronic Codebook) NUNCA deve ser utilizado para dados estruturados ou imagens (ex: pinguim do Linux), pois blocos idênticos de texto claro geram blocos cifrados idênticos, revelando a estrutura visual e os padrões do dado original!

3. Criptografia Assimétrica, Curvas Elípticas e Funções Hash

A Criptografia Assimétrica (ou de Chave Pública) resolve o problema de distribuição de chaves ao utilizar um par de chaves matematicamente correlacionadas: a Chave Pública (amplamente divulgada para qualquer pessoa) e a Chave Privada (mantida em segredo absoluto pelo seu titular). Mensagens cifradas com a chave pública só podem ser decifradas pela chave privada correspondente.

- **Algoritmos Assimétricos Principais**

RSA (baseado na dificuldade matemática de fatoração de números inteiros compostos por dois primos grandes; chaves recomendadas de 2048 ou 4096 bits); ECC (Elliptic Curve Cryptography - baseado no problema do logaritmo discreto em curvas elípticas; oferece segurança equivalente ao RSA com chaves drasticamente menores, ex: ECC de 256 bits equivale a RSA de 3072 bits, consumindo menos bateria e CPU); Diffie-Hellman (protocolo seguro para troca e estabelecimento de uma chave simétrica de sessão através de canal inseguro sem transmitir o segredo).

- **Funções Hash Criptográficas (Resumo Criptográfico)**

Funções matemáticas determinísticas unidirecionais que mapeiam uma entrada de tamanho arbitrário em uma saída de tamanho fixo (Digest). Propriedades obrigatórias: 1. Sentido Único / Unidirecional (impossível reverter o hash para obter a mensagem original); 2. Efeito Avalanche (pequena alteração de 1 bit na entrada altera drasticamente mais de 50% do hash resultante); 3. Resistência a Colisões (computacionalmente inviável encontrar duas entradas distintas X e Y tais que $\text{Hash}(X) = \text{Hash}(Y)$).

- **Famílias de Algoritmos Hash**

MD5 (saída de 128 bits - vulnerável e inseguro); SHA-1 (saída de 160 bits - vulnerável a colisões práticas); SHA-2 (SHA-256 e SHA-512 - padrão robusto e seguro adotado na NF-e e certificados digitais); SHA-3 (Keccak - arquitetura baseada em esponja criptográfica).

ALERTA DE PROVA - USO DE CHAVES ASSIMÉTRICAS

Para CONFIDENCIALIDADE (sigilo): Cifra com a Chave PÚBLICA do destinatário (apenas o destinatário abre com sua privada). Para AUTENTICIDADE e ASSINATURA DIGITAL: Cifra o hash com a Chave PRIVADA do emissor (qualquer um valida com a pública do emissor).

4. Assinatura Digital, ICP-Brasil e Documentos Fiscais Eletrônicos

A Assinatura Digital é um mecanismo criptográfico que assegura a Autenticidade, a Integridade e o Não Repúdio de documentos eletrônicos, possuindo plena validade jurídica equiparada à assinatura de próprio punho com firma reconhecida (Medida Provisória nº 2.200-2/2001).

- **Processo de Geração e Validação da Assinatura Digital**

Geração: O emissor gera o Hash do documento original e o cifra utilizando a sua CHAVE PRIVADA, anexando a assinatura ao arquivo. Validação: O receptor calcula o Hash do documento recebido e decifra a assinatura com a CHAVE PÚBLICA do emissor; se ambos os hashes forem idênticos, comprova-se que o documento não sofreu alteração (integridade) e partiu inequivocamente do titular da chave privada (autenticidade e não repúdio).

- **Infraestrutura de Chaves Públicas Brasileira (ICP-Brasil)**

Hierarquia de confiança instituída pela MP 2.200-2/2001: 1. AC-Raiz (Instituto Nacional de Tecnologia da Informação - ITI, única autoridade com certificado autoassinado); 2. Autoridades Certificadoras (ACs de 1º e 2º nível - emitem, suspendem e revogam certificados); 3. Autoridades de Registro (ARs - realizam a identificação presencial e validação documental dos titulares).

- **Tipos de Certificados Digitais ICP-Brasil**

Certificados Tipo A (Assinatura Digital) e Tipo S (Sigilo/Confidencialidade). Padrão A1: Chave gerada por software, armazenada no computador, com validade de 1 ano; Padrão A3: Chave gerada e armazenada em hardware criptográfico inviolável (Token USB, Smartcard ou HSM), onde a chave privada nunca sai do chip, com validade de até 3 ou 5 anos.

- **Aplicação em Documentos Fiscais (NF-e, NFC-e, EFD)**

A Nota Fiscal Eletrônica (Modelo 55) exige assinatura digital padrão XML-DSig com certificado digital padrão ICP-Brasil (e-CNPJ) antes de ser transmitida para autorização de uso no ambiente da SEFAZ.

PEGADINHA CLÁSSICA DE ASSINATURA DIGITAL

A assinatura digital NÃO provê confidencialidade (sigilo) do documento, pois o texto da mensagem viaja em texto claro acompanhado do hash assinado. Se houver necessidade de sigilo, o documento assinado deve ser subsequentemente cifrado.

5. Controle de Acesso, Autenticação Multifator e Gestão de Identidade

O Controle de Acesso assegura que apenas usuários, processos e dispositivos autorizados acessem recursos e dados sensíveis da organização, operando através de quatro etapas sucessivas: Identificação, Autenticação, Autorização e Auditoria (Accountability).

- **Os 3 Fatores de Autenticação**

1. Algo que você SABE (senhas, PINs, perguntas de segurança); 2. Algo que você TEM (smartcard, token OTP, chave física FIDO2/U2F, smartphone); 3. Algo que você É (biometria de impressão digital, reconhecimento facial, íris, voz). Autenticação Multifator (MFA) exige a combinação de pelo menos dois fatores de categorias DISTINTAS (ex: senha + OTP no celular).

- **Modelos Formais de Controle de Acesso**

DAC (Discretionary Access Control - o proprietário do recurso decide quem tem acesso via listas ACLs); MAC (Mandatory Access Control - o sistema impõe acesso com base em rótulos de sensibilidade e autorizações de segurança / Clearances, ex: Confidencial, Secreto); RBAC (Role-Based Access Control - acessos atribuídos com base nas funções/cargos desempenhados na organização); ABAC (Attribute-Based Access Control - controle dinâmico baseado em atributos do usuário, do recurso, da ação e do ambiente como horário e geolocalização).

- **Protocolos de Federação e Identidade Digital**

OAuth 2.0 (framework de AUTORIZAÇÃO baseado em tokens de acesso que permite a aplicações de terceiros acessar recursos sem compartilhar senhas); OpenID Connect / OIDC (camada de AUTENTICAÇÃO construída sobre o OAuth 2.0 que fornece ID Tokens); SAML 2.0 (padrão baseado em XML para Single Sign-On corporativo); JWT (JSON Web Tokens - tokens compactos e autocontidos assinados digitalmente, estruturados em três partes separadas por pontos: Header.Payload.Signature).

DIFERENÇA CRÍTICA: OAUTH 2.0 VERSUS OPENID CONNECT

OAuth 2.0 é um protocolo de AUTORIZAÇÃO (concede permissão de acesso via Access Token). OpenID Connect (OIDC) é um protocolo de AUTENTICAÇÃO (comprova a identidade do usuário via ID Token).

6. Segurança de Redes: Firewalls, IDS/IPS, VPN e Protocolos Seguros

A segurança perimetral e de transporte de dados protege as redes corporativas da administração tributária contra interceptações, intrusões não autorizadas e ataques de negação de serviço.

- Gerações e Tipos de Firewalls

1. Filtragem de Pacotes / Stateless (analisa cabeçalhos IP/Porta individualmente sem guardar estado da conexão); 2. Stateful Inspection / Com Estado (mantém uma tabela de estado e inspeciona fluxos completos de conexão TCP); 3. Proxy de Aplicação (atua na camada 7 inspecionando o payload específico do protocolo); 4. Next-Generation Firewall (NGFW - integra stateful inspection, Deep Packet Inspection / DPI, prevenção de intrusão IPS integrada e controle de aplicações em tempo real).

- Sistemas de Detecção e Prevenção de Intrusão (IDS versus IPS)

IDS (Intrusion Detection System): Opera em modo passivo (espelhamento de tráfego), monitora a rede e gera ALERTAS de segurança sem bloquear o tráfego. IPS (Intrusion Prevention System): Opera em modo ativo ('in-line'), monitora o fluxo em tempo real e BLOQUEIA pacotes maliciosos imediatamente. Métodos de Detecção: Baseado em Assinaturas (conhecidas) versus Baseado em Anomalias / Comportamento (detecta ataques de dia zero / Zero-Day).

- VPN e o Protocolo IPsec

Virtual Private Network para túneis criptografados em redes públicas. O protocolo IPsec opera na Camada de Rede (Camada 3) com dois protocolos principais: AH (Authentication Header - provê integridade e autenticidade, mas NÃO cifra os dados) e ESP (Encapsulating Security Payload - provê integridade, autenticidade E CONFIDENCIALIDADE). Modos de Operação: Modo Transporte (cifra apenas o payload IP) versus Modo Túnel (cifra o pacote IP inteiro e anexa um novo cabeçalho IP externo).

- Protocolo TLS 1.3 (Transport Layer Security)

Protocolo de segurança na camada de transporte que protege o HTTPS. O TLS 1.3 eliminou cifras obsoletas (DES, RC4, MD5), reduziu a negociação do Handshake para 1 RTT (ou 0-RTT com retomada de sessão) e tornou mandatório o sigilo progressivo perfeito (Perfect Forward Secrecy - PFS com ECDHE).

ALERTA DE PROVA - IPSEC: AH VERSUS ESP

O protocolo AH (Authentication Header) NÃO fornece confidencialidade/sigilo (os dados não são criptografados). Para haver criptografia e sigilo no IPsec, é obrigatório utilizar o protocolo ESP (Encapsulating Security Payload)!

7. Ameaças Cibernéticas, Malwares e Engenharia Social

Compreensão detalhada dos tipos de códigos maliciosos (Malwares), vetores de ataque cibernético e técnicas de manipulação psicológica que visam comprometer sistemas governamentais.

- **Taxonomia dos Malwares**

Vírus: Código malicioso que infecta arquivos legítimos e EXIGE a execução do programa hospedeiro ou ação do usuário para se propagar; Worm: Programa autônomo que se propaga AUTOMATICAMENTE pelas redes explorando vulnerabilidades ativas, sem necessidade de hospedeiro nem intervenção humana; Trojan (Cavalo de Troia): Programa aparentemente inofensivo ou útil que executa funções maliciosas ocultas (abertura de portas traseiras / Backdoors); Spyware: Software espião que coleta dados do usuário sem autorização (subdivide-se em Keyloggers que capturam teclas e Screenloggers que capturam telas); Rootkit: Conjunto de ferramentas complexas que se oculta nas camadas mais profundas do sistema operacional (Kernel) para manter acesso privilegiado furtivo; Ransomware: Malware que sequestra os arquivos da vítima através de criptografia forte, exigindo pagamento de resgate (geralmente em criptomoedas).

- **Técnicas de Engenharia Social**

Phishing (mensagens fraudulentas em massa simulando entidades confiáveis para roubar credenciais); Spear Phishing (phishing altamente direcionado e personalizado a um servidor ou órgão específico); Whaling (ataque direcionado à alta liderança e diretores); Smishing (via SMS); Vishing (via chamadas telefônicas de voz); Pretexting (criação de um cenário fictício para induzir a vítima a fornecer informações restritas).

- **Ataques de Negação de Serviço (DoS e DDoS)**

Ataques volumétricos que visam esgotar os recursos de processamento, memória ou largura de banda de servidores fazendários para torná-los indisponíveis. DDoS (Distributed Denial of Service) emprega milhares de computadores zumbis infectados (Botnets) distribuídos geograficamente.

DIFERENÇA CRÍTICA: VÍRUS VERSUS WORM

Vírus precisa de arquivo HOSPEDEIRO e AÇÃO do usuário para rodar. Worm é AUTÔNOMO, não precisa de hospedeiro e se propaga sozinho pela rede.

8. Segurança em Aplicações Web e OWASP Top 10

A Open Web Application Security Project (OWASP) é a referência mundial de segurança de software, publicando periodicamente o ranking das vulnerabilidades e riscos mais críticos em aplicações web.

- **OWASP Top 10:2021 - Principais Categorias**

A01: Broken Access Control (Quebra de Controle de Acesso - usuários acessam recursos fora de suas permissões, ex: IDOR / referências diretas a objetos); A02: Cryptographic Failures (Falhas Criptográficas - uso de algoritmos fracos ou senhas em texto claro); A03: Injection (Injeção de Código - SQL Injection, Command Injection, LDAP Injection); A04: Insecure Design; A05: Security Misconfiguration; A06: Vulnerable and Outdated Components; A07: Identification and Authentication Failures; A08: Software and Data Integrity Failures; A09: Security Logging and Monitoring Failures; A10: Server-Side Request Forgery (SSRF - servidor é induzido a fazer requisições a recursos internos não autorizados).

- **Ataques de Injeção SQL (SQL Injection - SQLi)**

Ocorre quando dados fornecidos pelo usuário são concatenados diretamente na consulta SQL sem sanitização. Prevenção Definitiva: Uso mandatório de Consultas Parametrizadas / Instruções Preparadas (Prepared Statements com Parameterized Queries) e ORMs seguros.

- **Cross-Site Scripting (XSS)**

Injeção de scripts maliciosos (geralmente JavaScript) que são executados no navegador de outros usuários legítimos para roubo de cookies de sessão. Tipos: Stored XSS (script persiste no banco de dados), Reflected XSS (script reflete na resposta HTTP imediata) e DOM-based XSS. Prevenção: Codificação contextual de saída (Context-Aware Output Encoding) e uso de cabeçalho Content Security Policy (CSP).

- **Cross-Site Request Forgery (CSRF)**

Induz a vítima autenticada a executar ações indesejadas em uma aplicação web na qual ela possui sessão ativa. Prevenção: Uso de Tokens Anti-CSRF sincronizados e cookies com atributo SameSite=Strict.

A SOLUÇÃO UNIVERSAL CONTRA SQL INJECTION

A única defesa 100% eficaz contra SQL Injection em provas de concurso é o uso de Prepared Statements (Consultas Parametrizadas). Técnicas de filtros de caracteres ou substituição de aspas são consideradas insuficientes.

9. Lei Geral de Proteção de Dados Pessoais (LGPD - Lei nº 13.709/2018)

A LGPD disciplina o tratamento de dados pessoais em meios físicos e digitais por pessoa natural ou jurídica de direito público ou privado, visando proteger os direitos fundamentais de liberdade, privacidade e o livre desenvolvimento da personalidade.

- **Conceitos Fundamentais da LGPD**

Dado Pessoal (informação relacionada a pessoa natural identificada ou identificável); Dado Pessoal Sensível (dados sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico); Dado Anonimizado (dado que não permite identificação do titular considerando a utilização de meios técnicos razoáveis e disponíveis na ocasião de seu tratamento - NÃO é considerado dado pessoal para fins da lei).

- **Agentes de Tratamento e o Encarregado**

Controlador (pessoa a quem competem as decisões referentes ao tratamento de dados pessoais); Operador (pessoa que realiza o tratamento de dados em nome do controlador); Encarregado / DPO (pessoa indicada pelo controlador e operador para atuar como canal de comunicação entre o controlador, os titulares dos dados e a ANPD).

- **Princípios da LGPD (Art. 6º)**

Finalidade, Adequação, Necessidade (Minimização de dados), Livre Acesso, Qualidade dos Dados, Transparência, Segurança, Prevenção, Não Discriminação e Responsabilização/Prestação de Contas.

- **As 10 Bases Legais para Tratamento de Dados (Art. 7º)**

1. Consentimento do titular; 2. Cumprimento de obrigação legal ou regulatória pelo controlador; 3. Execução de políticas públicas pela administração pública; 4. Realização de estudos por órgão de pesquisa; 5. Execução de contrato; 6. Exercício regular de direitos em processo judicial ou administrativo; 7. Proteção da vida; 8. Tutela da saúde; 9. Legítimo interesse do controlador (NÃO se aplica a dados sensíveis); 10. Proteção do crédito.

- **Tratamento de Dados pelo Poder Público (Art. 23)**

O Poder Público (SEFAZ) pode tratar dados pessoais SEM consentimento do titular para o cumprimento de suas atribuições legais e a execução de políticas públicas de arrecadação e fiscalização tributária.

ALERTA DE PROVA - CONSENTIMENTO NA ADMINISTRAÇÃO PÚBLICA

A administração pública NÃO depende de consentimento do cidadão para tratar dados pessoais necessários ao cumprimento de obrigação legal ou à execução de suas atribuições fazendárias e fiscalizatórias legítimas (Art. 7º, II e III da LGPD).

10. As 10 Grandes Armadilhas de Segurança da Informação da FGV/CEBRASPE

Quadro analítico com as 10 principais armadilhas de Segurança da Informação, Criptografia e Legislação cobradas pelas bancas examinadoras.

- **Pegadinha 1: Chave Privada Assina, Chave Pública Verifica**

Na assinatura digital, o emissor cifra com a sua própria chave PRIVADA. Dizer que assina com a chave pública do destinatário é pegadinha clássica.

- **Pegadinha 2: Assinatura Digital NÃO Garante Sigilo**

Assinatura digital provê Autenticidade, Integridade e Não Repúdio. Sigilo/Confidencialidade exige criptografia separada.

- **Pegadinha 3: Worm NÃO Precisa de Hospedeiro**

Vírus infecta outros arquivos e precisa de execução. Worm é programa independente que navega e se multiplica sozinho pela rede.

- **Pegadinha 4: Modo ECB Preserva Padrões**

O modo ECB cifra blocos de forma isolada, sendo vulnerável a análise de padrões. Modos seguros como CBC usam encadeamento e IV.

- **Pegadinha 5: Hash é Unidirecional e NÃO Decifra**

Funções hash não possuem chave e não são reversíveis. Não existe 'decifrar um hash'; o que se faz é comparar resumos calculados.

- **Pegadinha 6: Prepared Statements é a Solução de SQL Injection**

A única solução definitiva reconhecida pela OWASP contra SQLi é o uso de consultas parametrizadas.

- **Pegadinha 7: OAuth 2.0 é Autorização, OIDC é Autenticação**

OAuth emite tokens de acesso a recursos. Quem identifica o usuário é a camada OpenID Connect com ID Token.

- **Pegadinha 8: IPsec AH NÃO Criptografa**

O cabeçalho AH do IPsec provê apenas autenticação e integridade. Quem realiza criptografia e sigilo é o ESP.

- **Pegadinha 9: Dado Anonimizado NÃO é Dado Pessoal**

Se o processo de anonimização for irreversível por meios técnicos razoáveis, a LGPD deixa de se aplicar ao dado.

- **Pegadinha 10: Legítimo Interesse NÃO se Aplica a Dados Sensíveis**

O rol de bases legais para dados sensíveis (Art. 11 da LGPD) NÃO inclui o Legítimo Interesse.

SÍNTESE FINAL DE MEMORIZAÇÃO

Lembre-se: Chave privada assina; assinatura não esconde dados (não dá sigilo); Worm anda sozinho; no IPsec só o ESP cifra; e o Fisco não pede consentimento na LGPD!

GLOSSÁRIO DE SIGLAS E ABREVIATURAS

Consulte abaixo o significado e a expansão explicativa de todas as siglas contábeis, tributárias e de TI presentes nas apostilas de preparação:

ACID	Atomicidade, Consistência, Isolamento e Durabilidade. Propriedades fundamentais para transações em SGBDs.
BI	Business Intelligence. Inteligência de Negócios para mineração e análise estratégica de dados.
CAP	Consistência, Disponibilidade e Tolerância a Partições. Teorema limitador para sistemas distribuídos.
CEBRASPE	Centro de Seleção e de Promoção de Eventos. Banca examinadora oficial de concursos públicos.
CFC	Conselho Federal de Contabilidade. Órgão responsável pela edição das NBCs no território nacional.
CIAP	Controle de Crédito de ICMS do Ativo Permanente. Controle fiscal de apropriação de créditos de bens imobilizados.
CID	Confidencialidade, Integridade e Disponibilidade. Pilares de sustentação da Segurança da Informação.
COBIT	Control Objectives for Information and Related Technologies. Framework global de Governança de TI.
CPC	Comitê de Pronunciamentos Contábeis. Emissor de normas convergentes com padrões internacionais.
FGV	Fundação Getulio Vargas. Banca examinadora de certames e instituição de pesquisa econômica.
ICMS	Imposto sobre Operações Relativas à Circulação de Mercadorias e Prestações de Serviços de Transporte.
IPVA	Imposto sobre a Propriedade de Veículos Automotores. Tributo de competência estadual.
ITD	Imposto sobre Transmissão Causa Mortis e Doação. Tributo sobre heranças e doações na Bahia.
ITIL	Information Technology Infrastructure Library. Boas práticas de Gerenciamento de Serviços de TI.
KDD	Knowledge Discovery in Databases. Processo sistemático de descoberta de conhecimento em bases de dados.
LDO	Lei de Diretrizes Orçamentárias. Define as metas e prioridades para o orçamento do exercício seguinte.
LOA	Lei Orçamentária Anual. Estima as receitas e fixa as despesas públicas para o exercício financeiro.
NBC TA	Normas Brasileiras de Contabilidade Técnicas de Auditoria Independente. Alinhadas ao padrão internacional.
NBC TI	Normas Brasileiras de Contabilidade Técnicas de Auditoria Interna. Foco nos processos organizacionais.
NoSQL	Not Only SQL. Família de SGBDs não relacionais estruturados para alto desempenho e escalabilidade.
OLAP	Online Analytical Processing. Ferramentas analíticas baseadas em cubos de dados multidimensionais.
PAF-BA	Processo Administrativo Fiscal do Estado da Bahia. Lei nº 3.956/1981 que regula o contencioso.
PPA	Plano Plurianual. Planejamento estratégico governamental de médio prazo (4 anos).
RICMS-BA	Regulamento do ICMS do Estado da Bahia. Decreto regulamentador do principal imposto estadual.
RUP	Rational Unified Process. Processo de desenvolvimento de software disciplinado e preditivo.
SEFAZ-BA	Secretaria da Fazenda do Estado da Bahia. Órgão de arrecadação e controle fiscal baiano.

SGBD	Sistema de Gerenciamento de Banco de Dados. Software de controle e armazenamento seguro de dados.
SQL	Structured Query Language. Linguagem declarativa padrão para consulta em SGBDs relacionais.
TI	Tecnologia da Informação. Recursos de hardware, software e infraestrutura de rede corporativa.
XP	Extreme Programming. Metodologia ágil de engenharia de software focada em excelência técnica.